

● ASEGURAMIENTO DE LA CALIDAD DEL SOFTWARE

Informe de Pruebas

Sistema de gestión de pedidos · Pruebas funcionales, de seguridad y de rendimiento

Angie Aguilar Alemán **Jonathan Sancho Loaiza**

Jeremy Montero Araya **Dereck Cuadra González**

Instituto Tecnológico de Costa Rica · Ingeniería en Computación · I Semestre 2026 · Prof. Marcos Rodríguez



QA

Introducción

Informe de resultados que verifica, con evidencia objetiva, si el sistema cumple los estándares de calidad requeridos antes de su entrega. A diferencia del plan de pruebas, no describe la estrategia: se enfoca en los hallazgos de la ejecución.



Funcionales

Comportamiento esperado de los flujos principales



Seguridad

Vulnerabilidades identificadas en la aplicación



Rendimiento

Estabilidad bajo carga concurrente (k6)

60

casos de prueba ejecutados

Herramientas

k6 · Postman

Entorno local de desarrollo

● RESULTADOS

Alcance y metodología

Los 60 casos se agrupan en tres categorías, cada una con su criterio de aceptación. Toda la evidencia fue recopilada de forma objetiva mediante Postman y k6.

38

Pruebas funcionales

4 módulos · Postman

14

Pruebas de seguridad

3 categorías · Postman

7

Escenarios de rendimiento

Carga y estrés · k6

80%

Criterio de aceptación

Se estableció un mínimo del 80% de aprobación por módulo. Resultado de rendimiento bajo entorno local: puede diferir en producción.

Aprobación por módulo

Módulo	% Aprobación	Estado
Validaciones generales	100%	APROBADO
Registro y Login	90%	APROBADO
Funciones de Administrador	85%	APROBADO
CRUD de Pedidos	54.5%	REPROBADO

38 casos en 4 módulos · umbral del 80%. CRUD de Pedidos queda muy por debajo (54.5%) porque varias operaciones del backend no fueron expuestas en el frontend del usuario regular.

Aprobación global

81.6%

Cumple el umbral del 80%,
pero con calidad heterogénea
entre módulos

Conclusiones funcionales



Autenticación y validaciones, sólidas

Registro/Login, Administrador y Validaciones superan el umbral. Buen manejo de códigos HTTP, JSON y actualización de perfil.



CRUD de Pedidos: atención prioritaria

Más de la mitad de los casos falla: operaciones disponibles en el backend pero no habilitadas en el frontend del usuario regular.



Riesgo de usabilidad (TC-33 / TC-34)

Ausencia de mensajes de confirmación al ejecutar acciones destructivas como eliminar usuarios o pedidos.

Aprobación por categoría

Categoría	Total	Pasa	Falla	% Aprob.	Estado
Control de acceso y autenticación	7	7	0	100%	APROBADO
Configuración de seguridad HTTP	4	3	0	75%	APROBADO
Protección contra inyección y XSS	3	2	1	66.7%	REPROBADO



Supera el criterio del 80%, pero la categoría de inyección y XSS queda por debajo del umbral por el defecto crítico de XSS almacenado (TC-27).

● HALLAZGO DE MAYOR SEVERIDAD

XSS almacenado (TC-27)

CRITICAL

D-08 · Bloqueante

El sistema almacena etiquetas <script> en las descripciones de pedidos sin sanitizar. El código queda guardado en la base de datos y se ejecuta en el navegador de cualquier usuario que visualice el pedido.

Reconocida por OWASP Top 10 (2021). Su corrección es inmediata e innegociable antes de cualquier despliegue.

Fortalezas y otros hallazgos

- ✓ Autenticación, tokens JWT y control de acceso por roles correctos
- ✓ Resistente a inyección SQL (JPA/Hibernate parametrizado)
- ! D-09 · 404 expone el paquete Java interno (Major)
- ! Faltan headers CSP y Strict-Transport-Security

Seguridad global: 85.7% — supera el umbral, pero el XSS marca la prioridad #1 del informe.

Escenarios ejecutados con k6

TC	Escenario	Configuración	% Éxito	P95 (ms)	Estado
TC14	Registro masivo	30 VUs / 90s	100%	842	APROBADO
TC15	Login masivo	30 VUs / 90s	100%	424	APROBADO
TC29	Listar pedidos (pocos)	5 VUs / 100 it	100%	58	APROBADO
TC30	Listar pedidos (muchos)	5 VUs / 100 it	100%	2	APROBADO
TC45	Flujo carga (login+orden)	50 VUs / 3min	100%	368	APROBADO
TC59	Flujo carga (login+/me)	50 VUs / 3min	100%	1040	APROBADO
TC60	Estrés (rampa)	200 VUs / 2min	100%	63	APROBADO

Umbral de respuesta: 400 ms. Valores en rojo (TC14, TC59) lo superan bajo carga sostenida — son hallazgos documentados, no fallos funcionales. 100% de éxito en todos los checks.

● TIEMPOS DE RESPUESTA

Latencia bajo carga

P90 / P95 reflejan el comportamiento real bajo concurrencia, más allá del promedio. El P95 representa el tiempo máximo que experimentó el 95% de los usuarios.

842 ms

TC14 · Registro masivo (P95)

Costo del cifrado bcrypt con 30 VUs sin pausa

1 040 ms

TC59 · Login + perfil (P95)

Saturación del endpoint de auth bajo carga sostenida

< 60 ms

TC29 / TC30 · Consulta de pedidos

Operaciones de lectura excepcionalmente rápidas

63 ms

TC60 · Estrés con 200 VUs (P95)

Estable gracias a la simplicidad del endpoint

Solo 2 de 7 escenarios superan el umbral de 400 ms — ambos bajo carga sostenida sin pausa entre peticiones.

● CONCLUSIONES DE RENDIMIENTO

Estable bajo carga extrema

3 843

peticiones / segundo

TC60 · 200 VUs en rampa · 2 min

461 442 checks · 0 errores

● 100% de éxito

En las verificaciones de los siete escenarios, sin una sola falla registrada

● Sin caídas del servicio

El sistema respondió correctamente en todos los niveles de carga evaluados

● Lecturas < 60 ms

Los endpoints de consulta de pedidos confirman la eficiencia de las lecturas

● 2 hallazgos Major

TC14 y TC59 superan 400 ms bajo carga sostenida — no son fallos funcionales

El sistema demostró capacidad para operar bajo carga extrema sin degradación funcional ni pérdida de disponibilidad.

● DEFECTOS ENCONTRADOS

11 defectos por severidad

Clasificación según la escala de SonarQube. El módulo de CRUD de pedidos concentra la mayor cantidad de defectos (7 entre fallas y observaciones).

5	1	4	1
Blocker	Critical	Major	Minor
Edición/eliminación de pedidos ausente en la UI del usuario	XSS almacenado (D-08 · TC-27)	Rendimiento (×2), paginación admin, 404 expone backend	Contraseñas < 6 caracteres aceptadas (D-01)

Conclusión: debilidades importantes a nivel funcional (CRUD) y de seguridad (XSS) que deben resolverse antes de la entrega.

● EVALUACIÓN

Curso de acción propuesto

El sistema cumple el umbral del 80% en las tres categorías, pero el resultado global oculta diferencias de calidad entre módulos. Correcciones en tres niveles de prioridad:

Prioridad ALTA

- Corregir XSS almacenado (D-08): sanitizar en backend y escapar en frontend
- Habilitar edición y eliminación de pedidos en la UI del usuario (D-02 a D-06)
- Ambas son bloqueantes: deben resolverse antes de cualquier entrega a producción

Prioridad MEDIA

- Implementar paginación en la vista del administrador (D-07)
- Ocultar información interna del backend en errores 404 (D-09)
- Revisar rendimiento del flujo de auth bajo carga (D-10, D-11)

Prioridad BAJA

- Validar longitud mínima de contraseña en el registro (D-01)
- Diálogos de confirmación en acciones destructivas (TC-33, TC-34)
- Añadir headers CSP y Strict-Transport-Security

Recomendaciones del equipo



Sobre el proceso

Mantener el enfoque mixto: las pruebas manuales validan usabilidad y navegación; las automatizadas cubren escenarios repetitivos y de carga.



Sobre las herramientas

Postman y k6 fueron adecuados. Complementar con Selenium o Cypress para automatizar los casos funcionales hoy ejecutados manualmente.



Sobre el alcance

Incluir en futuros ciclos pruebas de usabilidad y de compatibilidad entre navegadores para una visión más completa de la calidad.

● CONCLUSIÓN

Listo para producción tras dos correcciones clave

El sistema cumple los umbrales de calidad en las tres categorías, con autenticación y rendimiento sólidos. Antes del despliegue deben resolverse el XSS almacenado (D-08) y la gestión de pedidos desde la interfaz del usuario (D-02 a D-06).

Referencias: k6 (Grafecas Group, 2023) · OWASP Top 10 (2021) · SonarQube (SonarSource, 2023)

Gracias